

Debriefing : identification, authentification, autorisation

Définitions

Identification

L'identification est l'action qui consiste à demander (ou donner) son identité.

Authentification

L'authentification est l'action qui consiste à vérifier (ou prouver) son identité.

Autorisation

L'autorisation est l'action qui consiste à accorder (ou se voir accorder) certaines permissions ou accès en fonction de l'identité (vérifiée).

Exemples

Mattermost

- L'identification se fait en rentrant votre numéro étudiant dans le champ « Username » de la page d'accueil.
- L'authentification se fait en donnant votre mot de passe de l'ENT dans le champ « Password » de la page d'accueil.
- L'autorisation dépend des équipes et salons. Toute personne authentifiée peut accéder à l'équipe « Chat de la BU ». Les étudiant-es et enseignant-es de la L2 info peuvent accéder aux salons `~sysadmin_*` de l'équipe correspondant à leur année. Seul-es les étudiant-es d'un groupe de projet peuvent accéder au salon de leur groupe (les étudiant-es des autres groupes, même authentifiés, ne peuvent pas lire les messages échangés sur le salon de votre groupe de projet).

SSH (du client auprès du serveur)

- L'identification du client auprès du serveur consiste à donner votre nom d'utilisateur sur le système distant (via la commande `ssh <user>@<domaine>` ou via l'option `User` du fichier `~/.ssh/config`)
- L'authentification du client auprès du serveur se fait soit en donnant le mot de passe de l'utilisateur correspondant sur le serveur, soit en prouvant qu'on possède une clef privée correspondant à une clef publique qui se trouve dans le fichier `<home_de_l'utilisateur>/.ssh/authorized_keys` sur le serveur.
- L'autorisation se fait lors de l'obtention du shell, qui peut être plus ou moins puissant. En général le shell est défini dans `/etc/passwd` pour l'utilisateur correspondant. Il est possible de spécifier un shell restreint via le fichier `<home_de_l'utilisateur>/.ssh/authorized_keys` (voir `man 5 authorized_keys`). Par exemple on peut limiter l'utilisateur à l'utilisation de `scp` (autrement dit l'utilisateur peut copier des fichiers mais pas exécuter des commandes sur le système distant), ou aux seules commandes `git`.

Sudo

- L'identification est implicite : il s'agit de l'utilisateur propriétaire du processus qui exécute la commande `sudo <commande>` (en général un shell).
- Authentification : l'utilisateur doit rentrer son mot de passe (comportement par défaut).
- Autorisation : si l'utilisateur fait partie des `sudoers`, la `<commande>` sera exécutée en tant que `root` (comportement par défaut).

Remarque : le fichier `/etc/sudoers` permet de définir des authentifications et autorisations plus fines que le comportement par défaut, par exemple, on peut spécifier que tel user n'a pas besoin de donner son mot de passe, ou que tel user ne peut exécuter que telle commande en tant que `root`.

Pénétrer dans l'enceinte de l'université

- identification : le nom sur la carte étudiant
- authentification : est-ce que la carte présentée ressemble à une carte étudiant délivrée par l'université (autorité de certification) et est-ce que votre tête ressemble à la photo qui se trouve sur la carte étudiant ?
- autorisation : si vous êtes authentifié-e, que la carte étudiant présentée mentionne l'année courante et qu'on est un jour ouvré, vous pouvez entrer à pieds (mais pas en voiture). Les enseignant-es peuvent aussi entrer pendant les vacances pour travailler au laboratoire à condition que leur nom ait été inscrit sur une feuille.

Examen à la fac

TODO.

Autres exemples

Amusez-vous à décrire d'autres situations d'identification/authentification/autorisation.